

Insecure Data Storage (OWASP Mobile M9)

Durante l'analisi dell'applicazione Booking.com è stata rilevata la presenza di dati personali sensibili conservati in chiaro all'interno dello storage locale del dispositivo Android. In particolare, sono stati ispezionati due tipi di archiviazione: le **Shared Preferences** e i **database SQLite** presenti nella directory privata dell'app (`/data/data/com.booking/`). In entrambi i casi è stato possibile leggere, senza alcuna cifratura o protezione aggiuntiva, informazioni identificative dell'utente quali nome, cognome, indirizzo e-mail, numero di telefono, data di nascita, paese di residenza e URL dell'avatar.

Tale condizione configura una vulnerabilità di tipo **Insecure Data Storage** (OWASP Mobile Top 10 – M9): un attaccante con accesso fisico al dispositivo (o con privilegi di root, ottenibili tramite emulatore o device compromesso) può esfiltrare questi dati senza dover interagire con le API di Booking.com e senza necessità di credenziali applicative.

Proof of Concept

1 – Shared Preferences

Tramite accesso alla shell ADB sull'emulatore, è stato ispezionato il file `mybooking.xml` (identico al file `remote_profile.xml`) situato in `/data/data/com.booking/shared_prefs/`. Il file XML contiene in chiaro l'indirizzo e-mail, il numero di telefono, nome, cognome e altri metadati dell'utente autenticato:

(user@kali)-[~]

\$ adb shell

emulator64_x86_64_arm64:/ \$ su

emulator64_x86_64_arm64:/ # cd data/data/com.booking/shared_prefs/

at mybooking.xml

<?xml version='1.0' encoding='utf-8' standalone='yes' ?>

<map>

<string name="pref3_title">UNKNOWN</string>

<boolean name="has_booking_pay" value="false" />

<string name="pref3avatar">{"available":true,"lastUpdate":123,8

{}</string>

<boolean name="pref3_assistant_available" value="true" />

<string name="pref3address">Via XX Settembre</string>

<string name="pref3_address_country">it</string>

<boolean name="is_genius_vip" value="false" />

<string name="email_details">[{"email_address":"mobsec24@gmail.com&
_is_business":0,"email_is_primary":1,"email_verified":1,"email_v
ription_frequency":1,"weekly":1,"subscription_manager_url":"h
ng.com/subscription_manager.html?aid\u003d339530\u0026business_unit\u003dbooking\u0026
FT08BPE9\u0026message_channel\u003demail"}]</string>

<boolean name="has_wallet" value="false" />

<string name="pref3lastname">Rossi</string>

<string name="pref3city">Genova</string>

<string name="pref3googlestate">{"hasBookingPassword":false,"id":
77245668859618">

<int name="pref3isgenius" value="1" />

<string name="pref3_private_country">it</string>

<set name="genius_vip_benefits" />

<int name="genius_level" value="1" />

<boolean name="assistant_language_support" value="true" />

<string name="pref3bs_country"></string>

<string name="pref3bs_phone"></string>

<string name="pref3bs_street"></string>

<string name="pref3travel_purpose">NOT_SELECTED</string>

<string name="genius_vip_recruitment_mode"></string>

<string name="pref3smoking">UNSPECIFIED</string>

<string name="pref3email">mobsec24@gmail.com</string>

<string name="pref3bs_city"></string>

<boolean name="has_rewards" value="false" />

<int name="pref3subscribed" value="0" />

<boolean name="mybooking_token_binds_device_id" value="true" />

<int name="variant_edit_email" value="1" />

<string name="pref3country">it</string>

<boolean name="pref3_hc_available" value="true" />

<boolean name="is_personalisation_disabled" value="false" />

<string name="pref3vat_number"></string>

<boolean name="pref3account_details_phone" value="false" />

<boolean name="pref3_partner_chat_available" value="true" />

<string name="pref3gender">OTHER</string>

<string name="pref3phone">+39 333 333 3333</string>

<boolean name="is_grap_eligible" value="false" />

<string name="user_identities">[]</string>

<int name="mybooking_login_type" value="1" />

<string name="pref3company_name"></string>

<string name="pref3bs_zip"></string>

<boolean name="pref3account_details_email" value="true" />

<string name="pref3zipcode">16121</string>

<int name="pref3uid" value="1018679306" />

<string name="pref3firstname">Paolo</string>

</map>

```

at remote_profile.xml
<?xml version='1.0' encoding='utf-8' standalone='yes'?>
<map>
  <string name="pref3_title">UNKNOWN</string>
  <boolean name="has_booking_pay" value="false" />
  <string name="pref3avatar">{"available":true,"lastUpdate":123,
  }}</string>
  <boolean name="pref3_assistant_available" value="true" />
  <string name="pref3address">Via XX Settembre</string>
  <string name="pref3_address_country">it</string>
  <boolean name="is_genius_vip" value="false" />
  <string name="email_details">{"email_address":"mobsec24@gmail.com&
_is_business":0,"email_is_primary":1,"email_verified":1,"email_desc
ription_frequency":0,"weekly_subscription_manager_url":"https://www.
ng.com/subscription_manager.html?aid\u003d339530\u0026business_unit\u003dbooking\u0026e
FT08BPE9\u0026message_channel\u003demail"}</string>
  <boolean name="has_wallet" value="false" />
  <string name="pref3lastname">Rossi</string>
  <string name="pref3city">Genova</string>
  <string name="pref3googlestate">{"hasBookingPassword":false,"id":
7724566885961}</string>
  <int name="pref3isgenius" value="1" />
  <string name="pref3_private_country">it</string>
  <set name="genius_vip_benefits" />
  <int name="genius_level" value="1" />
  <boolean name="assistant_language_support" value="true" />
  <string name="pref3bs_country"></string>
  <string name="pref3bs_phone"></string>
  <string name="pref3bs_street"></string>
  <string name="pref3travel_purpose">NOT_SELECTED</string>
  <string name="genius_vip_recruitment_mode"></string>
  <string name="pref3smoking">UNSPECIFIED</string>
  <string name="pref3email">mobsec24@gmail.com</string>
  <string name="pref3bs_city"></string>
  <boolean name="has_rewards" value="false" />
  <int name="pref3subscribed" value="0" />
  <int name="variant_edit_email" value="1" />
  <string name="pref3country">it</string>
  <boolean name="pref3_hc_available" value="true" />
  <boolean name="is_personalisation_disabled" value="false" />
  <string name="pref3vat_number"></string>
  <boolean name="pref3account_details_phone" value="false" />
  <boolean name="pref3_partner_chat_available" value="true" />
  <string name="pref3gender">OTHER</string>
  <string name="pref3phone">+39 333 333 3333</string>
  <boolean name="is_grap_eligible" value="false" />
  <string name="user_identities">[]</string>
  <string name="pref3company_name"></string>
  <string name="pref3bs_zip"></string>
  <boolean name="pref3account_details_email" value="true" />
  <string name="pref3zipcode">16121</string>
  <int name="pref3uid" value="1018679306" />
  <string name="pref3firstname">Paolo</string>
</map>

```

I file delle Shared Preferences risultano leggibili da qualsiasi processo con accesso root al filesystem, o tramite ADB su dispositivi con debug USB abilitato / emulatori.

2 – Database SQLite (Apollo Cache)

È stato inoltre analizzato il database SQLite denominato `account_data_cache` presente nella directory dei database dell'app. Si tratta di una cache locale del client GraphQL Apollo che replica i dati restituiti dall'API. L'ispezione tramite `sqlite3` ha rivelato la presenza di record contenenti dati personali in chiaro, organizzati per chiave logica:

```
(user@kali)-[~]
$ adb shell
emulator64_x86_64_arm64:/ $ su
emulator64_x86_64_arm64:/ # cd data/data/com.booking
com.booking/ com.breel.wallpapers18/
emulator64_x86_64_arm64:/ # cd data/data/com.booking/databases/
emulator64_x86_64_arm64:/data/data/com.booking/databases # cp account_data_cache /sdcard
emulator64_x86_64_arm64:/data/data/com.booking/databases # exit
emulator64_x86_64_arm64:/ $ exit

(user@kali)-[~]
$ adb pull /sdcard/account_data_cache_v2
/sdcard/account_data_cache_v2: 1 file pulled, 0 skipped. 4.7 MB/s (24576 bytes in 0.005s)

(user@kali)-[~]
$ sqlite3 account_data_cache_v2
SQLite version 3.39.2 2022-07-21 15:24:47
Enter ".help" for usage hints.
sqlite> .tables
android_metadata records
sqlite> SELECT * FROM records;
121|personalProfile.personalData|{"firstName":"Paolo","lastName":"Rossi","gender":"MALE","shipCountry":"IT","displayName":"Paolo"}
122|personalProfile.address|{"address":"Via XX Settembre","city":"Genova","country":"IT"}
123|personalProfile.contactEmail|{"address":"mobsec24@gmail.com","isVerified":true}
124|personalProfile.contactPhone|{"number":"+39333333333","isVerified":false}
125|personalProfile.avatar.sizedUrls|{"square32":"https://lh3.googleusercontent.com/a/AF7QYd2-sclwFSy8MQ=s96-c32","square64":"https://lh3.googleusercontent.com/a/ACg8ocL7S249Iy8MQ=s96-c64","square96":"","square128":"https://lh3.googleusercontent.com/a/ACg8ocL7S249Iy8MQ=s96-c128","square256":"https://lh3.googleusercontent.com/a/ACg8ocL7S249IAdstjml6-c256"}
126|personalProfile.avatar|{"type":"GOOGLE","sizedUrls":"ApolloCacheReference{personalProfile.personalData}"}
127|personalProfile|{"personalData":"ApolloCacheReference{personalProfile.personalData}","address":"ApolloCacheReference{personalProfile.address}","contactEmail":"ApolloCacheReference{personalProfile.contactEmail}","contactPhone":"ApolloCacheReference{personalProfile.contactPhone}","avatar":"ApolloCacheReference{personalProfile.avatar}"}
128|QUERY_ROOT|{"personalProfile":"ApolloCacheReference{personalProfile}"}
sqlite>
```

Il database non è cifrato (nessuna chiave SQLCipher o equivalente). Tutti i campi sensibili — inclusi nome completo, indirizzo fisico, e-mail, numero di telefono, data di nascita e URL degli avatar Google — sono accessibili in chiaro con una singola query SQL.

Conclusioni

L'assenza di cifratura nello storage locale espone i dati personali dell'utente a chiunque abbia accesso al filesystem del dispositivo (root, ADB, backup non cifrati). La vulnerabilità è indipendente dalle protezioni lato server e costituisce un ulteriore vettore di attacco in scenari di compromissione del dispositivo. Si raccomanda l'adozione di cifratura a livello di file (es. *Android Keystore + EncryptedSharedPreferences / SQLCipher*) per tutti i dati personali conservati localmente, nonché la riduzione al minimo dei dati memorizzati in cache.